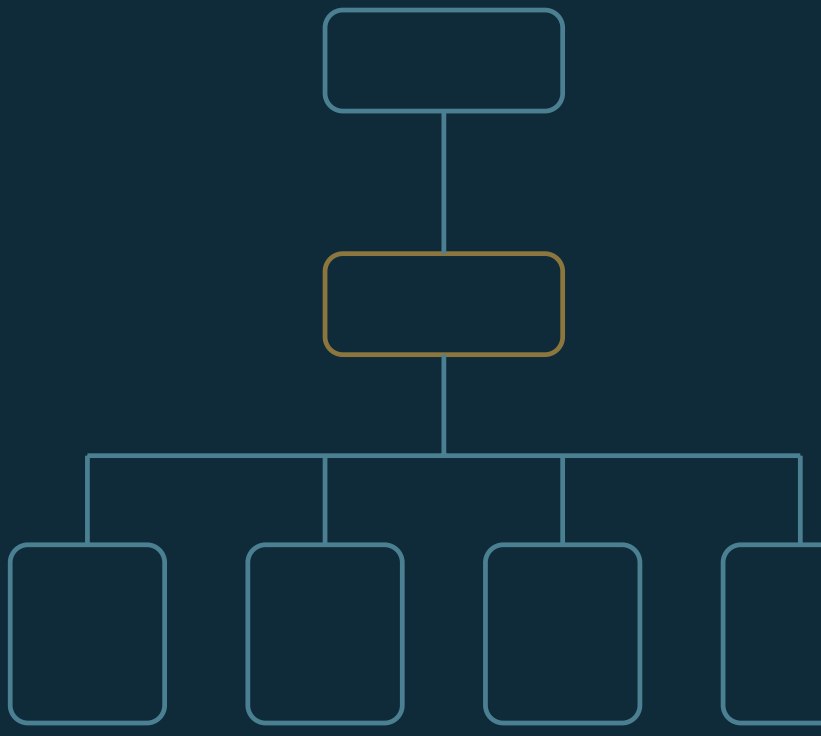
PRACTICAL WORKSHOP · DFIR

Building a Home DFIR Lab

Step by step: a small enterprise network on one PC, with Active Directory, a DMZ web server, SQL, a SIEM, an attacker and a forensic workstation.



Akshay Bhandari

Version 2.0 · October 2026

Meridian Freight is a fictional company created for training.

Contents

01 Introduction and purpose 2

02 Hardware and software 3

03 Architecture and network design 5

04 Building the lab, step by step 7

Step 4.1 · Prepare the host 7

Step 4.2 · Create the virtual networks 7

Step 4.3 · Build the firewall (fw01) 8

Step 4.4 · Build the base templates 9

Step 4.5 · Build the domain controller (DC01) 10

Step 4.6 · Create the Meridian Freight directory 11

Step 4.7 · Build the file server (FS01) 12

Step 4.8 · Add the workstations (WS01 to WS03) 13

Step 4.9 · Build the database server (SQL01) 14

Step 4.10 · Build the web server in the DMZ (WEB01) 14

Step 4.11 · Build the SIEM (SIEM01) 16

Step 4.12 · Add the attacker (KALI01) 17

Step 4.13 · Add the forensic workstation (ANALYST01) 18

05 Validation and troubleshooting 21

06 Making the lab DFIR-ready 24

6.1 Audit policy for every domain machine 24

6.2 Web server logs 25

6.3 Snapshots 26

6.4 Evidence handling habits 26

6.5 Prove that evidence is captured 26

07 Appendices and next steps 27

Appendix A · Machine inventory 27

Appendix B · Accounts and rights 27

Appendix C · Snapshot guide 28

Appendix D · Scripts 28

Appendix E · Glossary 35

01 Introduction and purpose

This guide walks you through building a small but realistic company network on one home PC, step by step, in the order I built it. At the end you have a working lab you can attack, break, investigate and reset in minutes.

What a DFIR lab is. Digital Forensics and Incident Response work happens inside company networks: domain controllers, file servers, databases, web servers and the logs they produce. A DFIR lab is a safe copy of that environment. You use it to learn how the pieces fit together, run attacks against it, and practise finding the evidence afterwards.

What you will build. Eleven virtual machines in five network zones behind one firewall:

- a firewall that is the only path between zones
- Active Directory with a realistic company: departments, groups, admin and service accounts
- a file server, a SQL database and a domain-joined web server in a DMZ
- a SIEM (Wazuh), an attacker (Kali) on the "internet" side, and an isolated forensic workstation

The company. The lab plays the part of *Meridian Freight*, a fictional 24-person logistics firm with six departments and a shipment-tracking website. Meridian Freight is invented for training; it is not based on any real client or engagement.

What you can do with it. Understand how enterprise Windows networks work, test attacks against a known setup, and practise investigations using real artefacts. A few weaknesses common in real companies are built in on purpose, and each is marked where it is created.

How each build step is written. Every step in chapter 04 follows the same pattern, so you always know where you are:

Part	Tells you
Purpose	What the step achieves
You need	What must already exist
Procedure	The exact actions and commands
Expected result	What you should see when it worked
Verify	A test to run before moving on
Common issues	Problems met during the real build, and the fix
Why it matters	The reason behind the design

Where something in this guide has not yet been tested end to end, it says so.

02 Hardware and software

The lab in this guide ran on one desktop with 64 GB of RAM. That is what I used, not what you must have: the same design runs on less if you start fewer machines at a time.

What I used

Item	My setup
Host PC	Intel i7-12700F, 64 GB RAM, Windows 11 Pro
Lab storage	256 GB SSD for busy VMs, 1 TB HDD for quiet VMs, templates and ISOs
Hypervisor	VMware Workstation 17.5
Management	Remote Desktop from a laptop to the host; working at the host's own screen works just as well

Software

Component	Version used
Firewall	OPNsense 26.7
Servers	Windows Server 2022 (evaluation, 180 days)
Workstations	Windows 11
Database	SQL Server 2022 Developer edition
SIEM	Wazuh 4.14 on Ubuntu Server 24.04 LTS
Attacker	Kali Linux 2026.3, VMware prebuilt image

Everything is free or a time-limited evaluation. Snapshots taken after each step (chapter 06) let you rebuild an expired evaluation quickly.

Running it on less

You never need all eleven machines running at once. Pick the profile that fits your RAM and start only what a task needs.

Profile	Host RAM	Run together	Leave off or skip
Full	64 GB	All 11 VMs (about 54 GB)	Nothing
Core	32 GB	fw01, DC01, FS01, one workstation, SIEM01 (about 22 GB)	SQL01, WEB01, KALI01, ANALYST01 until needed
Minimal	16 GB	fw01, DC01, one workstation (DC01 at 2 GB, workstation at 3 GB)	SIEM01 needs 8 GB on its own; add it only on a bigger host

Trade-offs: fewer workstations means fewer users to pivot between, and running without SIEM01 means reading logs on each machine instead of in one place. The design and every step stay the same.

Storage. Thin-provisioned disks grow as they fill, so plan roughly 40 GB per Windows VM and 100 GB for SIEM01 (approximate). Keep at least 15% free on every lab drive: when a drive fills, VMware pauses every VM stored on it.

Other hypervisors. The design works on Hyper-V, VirtualBox or Proxmox. The steps here use VMware's names (VMnet, NAT, host-only), so translate those to your platform's equivalents.

03 Architecture and network design

The lab is five isolated networks joined only by one firewall, fw01. Every connection between zones passes through it, so it can be allowed, blocked and logged in one place, the way a real company network is built.

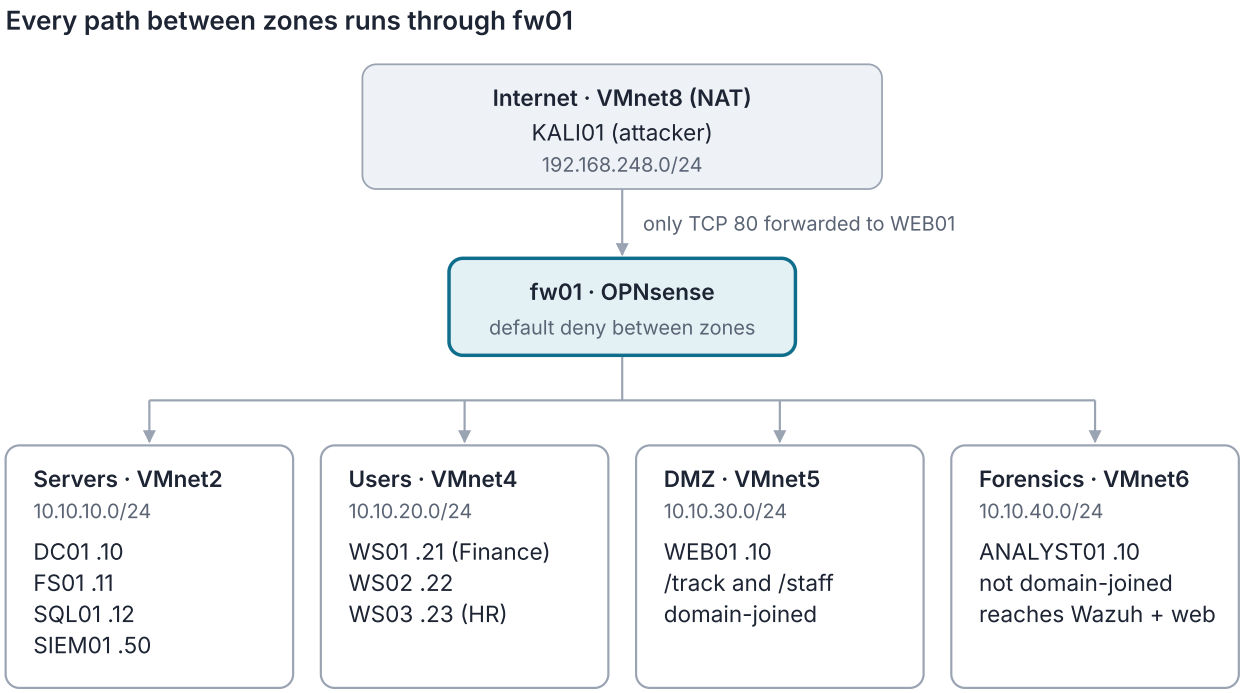


Figure 1 · Lab architecture: five zones, eleven VMs

From the internet side, the website on port 80 is the only way in. The domain controller, files and database are reachable only from inside.

The zones

Zone	VMware network	Subnet	Gateway	Machines	Purpose
Internet	VMnet8 (NAT)	192.168.248.0/24 (yours may differ)	VMware NAT	fw01 WAN, KALI01	Stands in for the internet
Servers	VMnet2 (host-only)	10.10.10.0/24	10.10.10.1	DC01, FS01, SQL01, SIEM01	Core company services
Users	VMnet4	10.10.20.0/24	10.10.20.1	WS01, WS02, WS03	Staff PCs
DMZ	VMnet5	10.10.30.0/24	10.10.30.1	WEB01	The public website
Forensics	VMnet6	10.10.40.0/24	10.10.40.1	ANALYST01	Evidence work, apart from the domain

Every machine's address is listed in Appendix A.

What may talk to what

Each firewall interface blocks everything by default. Only these paths are opened, each in the build step that needs it:

From	To	Allowed	Opened in
Servers	Internet	Updates and downloads	4.3
Users	Servers	Domain services, file shares, SQL	4.8
Users	WEB01	HTTP	4.10
WEB01	DC01	Domain services only	4.10
WEB01	SQL01	TCP 1433 only	4.10
Internet	WEB01	TCP 80, through a port forward	4.12
ANALYST01	SIEM01, internet	HTTPS to Wazuh, web for tools	4.13

This table describes the design. Compare it with your own firewall's rule list after building.

Separation from the home network

The lab networks are virtual and have no route to your home network, with two deliberate exceptions:

- **The management adapter.** The host itself joins the Servers network as 10.10.10.254, so its browser can open the firewall and Wazuh consoles. Nothing inside the lab uses it as a route.
- **The NAT network.** fw01's WAN and Kali share VMware's NAT network, which reaches the internet through the host. Step 4.12 adds a host firewall rule so that this path cannot be used to slip into the lab around fw01.

04 Building the lab, step by step

The steps run in dependency order: nothing uses a component that has not been built yet. Finish each step's Verify before starting the next, and take a snapshot when it passes.

Step 4.1 · Prepare the host

Purpose. Make the host PC stable enough to run VMs for hours without sleeping, restarting or filling up.

You need. Administrator access to the host and VMware Workstation installed.

Procedure.

1. Decide where VMs live: busy VMs (firewall, domain controller, servers, workstations) on SSD; SIEM, Kali, the forensic workstation, templates and ISO files on HDD.
2. Stop the host from sleeping or hibernating. In an elevated PowerShell:

```
powercfg /change standby-timeout-ac 0
powercfg /change hibernate-timeout-ac 0
powercfg /hibernate off
powercfg /change monitor-timeout-ac 10
```

3. In Windows Update, set **active hours** to cover when you work, so an update restart does not kill running VMs.
4. If you manage the host remotely, enable Remote Desktop. I used RDP from a laptop; copy and paste into VM consoles through RDP is unreliable, so later steps keep commands short and use SSH where possible.

Expected result. The host stays awake with VMs running; the screen may turn off.

Verify. `powercfg /a` lists Hibernate as not available.

Common issues. A host that sleeps suspends every VM and the domain clock jumps. A host restarted by Windows Update with VMs running can leave a Windows guest in Automatic Repair; let the repair run, and shut VMs down cleanly in future (chapter 05).

Why it matters. Every other step assumes the VMs stay up and their clocks stay in step.

Step 4.2 · Create the virtual networks

Purpose. Create the five networks that separate the internet side, servers, users, DMZ and forensics.

You need. Step 4.1 done.

Procedure.

1. Open **Edit → Virtual Network Editor → Change Settings**.
2. Create or adjust the networks:

VMnet	Zone	Subnet	Type	Connect a host adapter	Local DHCP
VMnet8	Internet	as assigned by VMware	NAT	Yes	Yes

VMnet	Zone	Subnet	Type	Connect a host adapter	Local DHCP
VMnet2	Servers	10.10.10.0/24	Host-only	Yes	No
VMnet4	Users	10.10.20.0/24	Custom	No	No
VMnet5	DMZ	10.10.30.0/24	Custom	No	No
VMnet6	Forensics	10.10.40.0/24	Custom	No	No

3. Give the host's VMnet2 adapter a fixed address, so VMware cannot hand it 10.10.10.1, which belongs to the firewall:

```
New-NetIPAddress -InterfaceAlias "VMware Network Adapter VMnet2" -IPAddress 10.10.10.254 -PrefixLength 24
```

Expected result. The editor lists VMnet2, 4, 5, 6 and 8 with the subnets above; only VMnet2 and VMnet8 show a host connection.

Verify. `ipconfig | findstr /i "VMnet 10.10"` on the host shows VMnet2 at 10.10.10.254.

Common issues. Clicking Apply in the editor restarts VMware's network services under running VMs; afterwards the firewall can lose its WAN address. Make network changes with the lab shut down. Changing DHCP or host-adapter boxes on the wrong row is easy; recheck each row before Apply.

> **Warning.** Any VM left on NAT sits on the internet side of the firewall, next to the attacker. Cloned VMs inherit their template's adapter, so always set a clone's network before its first boot.

Why it matters. Separate networks give the lab the same structure as a real company and let you see, block and log traffic between parts of it.

Step 4.3 · Build the firewall (fw01)

Purpose. Install OPNsense as the router and firewall between all zones.

You need. Step 4.2 done and the OPNsense ISO.

Procedure.

1. New VM: 2 vCPU, 2 GB RAM, 20 GB disk.
2. Add **all five** network adapters before installing, in this order: NAT, VMnet2, VMnet4, VMnet5, VMnet6.
3. Install OPNsense and assign interfaces at the console:

Interface	Device	VMnet	Address
WAN	em0	VMnet8	DHCP
LAN (Servers)	em1	VMnet2	10.10.10.1/24
USERS	em2	VMnet4	10.10.20.1/24
DMZ	em3	VMnet5	10.10.30.1/24
FORENSICS	em4	VMnet6	10.10.40.1/24

4. From the host, open `https://10.10.10.1`, finish the wizard, set hostname `fw01` and domain `lab.local`.
5. For each optional interface (USERS, DMZ, FORENSICS): **Interfaces → [name]**, tick **Enable**, set **Static IPv4** and the address above, Save, Apply.
6. **Interfaces → WAN:** untick *Block private networks* and *Block bogon networks*. The lab's "internet" uses private addresses; with these ticked the firewall silently drops all of it.
7. Add a LAN rule allowing the Servers zone out to the internet, and create two port aliases for domain services, used in later steps:

Alias	Type	Content
AD_TCP	Port(s)	53, 88, 135, 389, 445, 464, 636, 3268, 49152-65535
AD_UDP	Port(s)	53, 88, 123, 389, 464

Expected result. Interfaces → Overview shows all five interfaces green with their addresses; WAN has a 192.168.x address from VMware.

Verify. From the host, `https://10.10.10.1` loads. Download a config backup (**System → Configuration → Backups**).

Common issues.

- *A saved change does nothing.* Rules, aliases and NAT each have their own **Apply** button.
- *A rule never matches.* The source port must be **any**; only the destination port is fixed. Pass rules must sit above any block rule they should beat.
- *Alias rejected as "not a network".* A space crept in before the value; enter each value on its own.
- *An interface is red with no address.* It was assigned but never enabled (procedure step 5).
- *Adding a NIC later breaks LAN and WAN.* VMware may give the new card a lower PCI slot, and every interface name shifts. Compare `ethernetN.pciSlotNumber` in the VM's .vmx file, then reassign each VMware adapter's network so slot order matches em0 to em4.

Why it matters. One choke point means every connection between zones can be controlled and, later, investigated.

Step 4.4 · Build the base templates

Purpose. Install Windows once for servers and once for workstations, then clone every machine from those two templates.

You need. The Windows Server 2022 and Windows 11 ISOs.

Procedure.

1. Create two VMs, **Windows Server 2022** and **Win11-Base** (2 vCPU, 4 GB each), on NAT so they can download updates.
2. Install Windows, VMware Tools and all updates.
3. Generalise each one and let it shut down:

```
C:\Windows\System32\Sysprep\sysprep.exe /generalize /oobe /shutdown
```

4. Never boot a template again. Move it to the HDD.

To clone a machine later: right-click the template → **Manage → Clone → Full clone**. Before its first boot, set the adapter to the zone's VMnet and tick **Connected** and **Connect at power on**. Then rename it and check the name:

```
Rename-Computer -NewName <NAME> -Restart
hostname
```

Expected result. A new clone boots to Windows setup and asks for region and account.

Verify. After renaming, `hostname` shows the new name.

Common issues.

- *Clone stops with "The computer restarted unexpectedly".* Press Shift+F10, run `regedit`, open `HKLM\SYSTEM\Setup\Status\ChildCompletion`, change `setup.exe` from 1 to 3, close, click OK. If it still loops, delete the clone and clone again.
- *Windows 11 setup insists on a Microsoft account.* Press Shift+F10 and run `start ms-cxh:localonly`.
- *A joined machine is missing from DNS.* It joined under its random setup name. Always check `hostname` before joining.

Why it matters. Sysprep gives every clone its own machine identity (SID). Clones sharing one cause strange domain problems later.

Step 4.5 · Build the domain controller (DC01)

Purpose. Create the `lab.local` domain with Active Directory and DNS.

You need. Steps 4.3 and 4.4 done.

Procedure.

1. Clone the server template onto **VMnet2**, rename it DC01.
2. In an elevated PowerShell:

```
New-NetIPAddress -InterfaceAlias "Ethernet0" -IPAddress 10.10.10.10 -PrefixLength 24 -
DefaultGateway 10.10.10.1
Set-DnsClientServerAddress -InterfaceAlias "Ethernet0" -ServerAddresses 127.0.0.1
Install-WindowsFeature AD-Domain-Services -IncludeManagementTools
Install-ADDSForest -DomainName lab.local -DomainNetbiosName LAB -InstallDns
```

3. After the automatic reboot, send internet lookups to the firewall and create reverse lookup zones, so tools can turn IP addresses back into names:

```
Set-DnsServerForwarder -IPAddress 10.10.10.1
Add-DnsServerPrimaryZone -NetworkId "10.10.20.0/24" -ReplicationScope Domain
Add-DnsServerPrimaryZone -NetworkId "10.10.30.0/24" -ReplicationScope Domain
Add-DnsServerPrimaryZone -NetworkId "10.10.10.0/24" -ReplicationScope Domain
```

The last line may report that the zone already exists; that is fine.

Expected result. You sign in as LAB\Administrator; Server Manager shows AD DS and DNS.

Verify. `Resolve-DnsName dc01.lab.local` returns 10.10.10.10, and `Resolve-DnsName microsoft.com` resolves through the firewall.

Common issues. A typo in an IP when adding DNS records creates a record in the wrong place; delete it with `Remove-DnsServerResourceRecord` and add it again.

Why it matters. Every Windows machine authenticates and finds services through DC01. In investigations it is also where most of the evidence about logons lives.

Step 4.6 · Create the Meridian Freight directory

Purpose. Fill the domain with a realistic company in one run.

You need. Step 4.5 done, and `New-LabOrg.ps1` (Appendix D) copied to DC01.

Procedure. As LAB\Administrator, in an elevated PowerShell in the script's folder:

```
Set-ExecutionPolicy -Scope Process Bypass -Force
.\New-LabOrg.ps1
```

It asks once for a password used by every lab account, then builds this under `OU=Corp`:

OU	Contents
Users → IT, HR, Finance, Sales, Operations, Management	24 staff, one OU per department
Groups	GG-IT, GG-HR, GG-Finance, GG-Sales, GG-Operations, GG-Management, GG-Helpdesk, GG-SQL-Admins
Admins	adm.ravi.kumar, adm.sarah.lewis (Domain Admins)
Service Accounts	svc_sql, svc_backup, svc_web
Computers → Workstations, Servers	New computers land in Workstations automatically

Admins are tiered: Ravi Kumar works as `ravi.kumar` and uses `adm.ravi.kumar` only for admin tasks.

> **Deliberate weaknesses.** The script builds four on purpose, for later exercises. Never do this in production.

#	Account	Weakness	Enables
1	svc_sql	Has an SPN; password never expires	Kerberoasting
2	chloe.martin	Kerberos pre-authentication turned off	AS-REP roasting
3	svc_backup	Member of Backup Operators; never expires	Privilege abuse
4	GG-Helpdesk	Can reset any staff password	ACL abuse path

Domain controllers patched for CVE-2026-20833 (July 2026 onward) no longer issue RC4 service tickets by default. To keep weakness 1 realistic, svc_sql was allowed RC4 by setting `msDS-SupportedEncryptionTypes` to `0x24`.

Expected result. The script ends with a summary of staff, admin and service account counts.

Verify. `(Get-ADUser -Filter * -SearchBase "OU=Corp,DC=lab,DC=local").Count` returns 29.

Common issues. The password must meet the domain's complexity rules, or account creation fails. The script is safe to re-run; existing objects are skipped.

Why it matters. Realistic names, departments and permissions make the evidence look like a real company's, and the weaknesses give you known starting points for attacks.

Step 4.7 · Build the file server (FS01)

Purpose. Give each department a private share and everyone a Public share, on a separate data disk.

You need. Step 4.6 done.

Procedure.

1. Clone the server template onto **VMnet2** and add a second 60 GB disk. Set IP 10.10.10.11, gateway 10.10.10.1, DNS 10.10.10.10. Rename to FS01, check `hostname`, then join:

```
Add-Computer -DomainName lab.local -Credential LAB\adm.ravi.kumar -Restart
```

2. On DC01, move it to the Servers OU:

```
Get-ADComputer FS01 | Move-ADObject -TargetPath "OU=Servers,OU=Computers,OU=Corp,DC=lab,DC=local"
```

3. On FS01, move the DVD drive off D: and create the data volume:

```
Get-CimInstance Win32_Volume -Filter "DriveType=5" | Set-CimInstance -Property @{DriveLetter='E:'}
Get-Disk | ? PartitionStyle -eq RAW | Initialize-Disk -PartitionStyle GPT -PassThru | New-Partition
-DriveLetter D -UseMaximumSize | Format-Volume -FileSystem NTFS -NewFileSystemLabel Data
```

4. Run `New-LabShares.ps1` (Appendix D). For IT, HR, Finance, Sales, Operations, Management and Public it creates `D:\Shares\<name>`, sets NTFS permissions (Administrators and SYSTEM full control; `GG-<dept>` or Domain Users modify) and shares the folder with access-based enumeration.
5. Add realistic files with the seed script (Appendix D).

Expected result. Seven shares, each holding a few believable files.

Verify. On FS01, `Get-SmbShare | ? Path -like "D:\Shares*"` lists seven shares with `FolderEnumerationMode` AccessBased. The per-user access test comes in step 4.8.

Common issues. "Access path already in use" when creating D: means the DVD drive still holds the letter (procedure step 3).

Why it matters. Two permission layers apply: the share permission is a coarse gate for network access, and NTFS decides what each person can do. Access-based enumeration hides folders a user cannot open **inside** a share; it does not hide share names (`net view \\FS01` lists all seven). The seed script does not backdate timestamps, because faked times leave their own artefacts and would mislead later exercises.

Step 4.8 · Add the workstations (WS01 to WS03)

Purpose. Add three staff PCs: WS01 for Finance, WS02 for any user, WS03 for HR.

You need. Steps 4.6 and 4.7 done.

Procedure.

1. On fw01, allow the Users zone to reach the servers (interface USERS, source USERS net):

Destination	Ports
10.10.10.10 (DC01)	AD_TCP, AD_UDP
10.10.10.11 (FS01)	TCP 445
10.10.10.12 (SQL01)	TCP 1433

2. Clone Win11-Base for each PC onto **VMnet4**, ticking **Connected** before first boot. Set the address (WS01 shown; WS02 .22, WS03 .23), rename, check `hostname`, join:

```
New-NetIPAddress -InterfaceAlias "Ethernet0" -IPAddress 10.10.20.21 -PrefixLength 24 -
DefaultGateway 10.10.20.1
Set-DnsClientServerAddress -InterfaceAlias "Ethernet0" -ServerAddresses 10.10.10.10
Rename-Computer -NewName WS01 -Restart
Add-Computer -DomainName lab.local -Credential LAB\adm.ravi.kumar -Restart
```

3. Map drives at sign-in. Save `MapDrives.ps1` and `MapDrives.cmd` (Appendix D) into `C:\Windows\SYSVOL\sysvol\lab.local\scripts` on DC01 (published as NETLOGON), then point every staff account at the wrapper:

```
Get-ADUser -Filter * -SearchBase "OU=Users,OU=Corp,DC=lab,DC=local" | Set-ADUser -ScriptPath
MapDrives.cmd
```

Expected result. Each PC sits in `OU=Workstations` (the org script redirected new computers there). Signing in as a staff member maps P: (Public) and S: (their department).

Verify. On WS01 as aisha.rahman (Finance): `Get-ChildItem \\FS01\Finance` lists files, and `Get-ChildItem \\FS01\HR` returns Access denied. On WS03 as priya.nair (HR), the opposite.

Common issues.

- *"The domain isn't available" at sign-in.* The VM's adapter is not connected.
- `Test-Path \\FS01\HR` *returns True for a Finance user.* Test-Path only checks the share exists; test access with `Get-ChildItem`.
- *A workstation boots into Automatic Repair.* Usually after the host lost power with VMs running; let the repair run.

Why it matters. Computers are grouped by what they are (workstation, server, DMZ); departments live on the user side, so a user gets their own drive on any PC. The `.cmd` wrapper exists because the logon-script field runs a file directly, and Windows opens `.ps1` files in Notepad instead of running them.

Step 4.9 · Build the database server (SQL01)

Purpose. Run SQL Server 2022 under the domain account svc_sql, with a MeridianOps database that staff reach using their Windows sign-in.

You need. Step 4.8 done, and the SQL Server 2022 Developer **ISO** (the online installer for 2022 has been retired; choose "Download Media" → ISO).

Procedure.

1. Clone the server template onto **VMnet2** with a 60 GB data disk (D:). Set IP 10.10.10.12, DNS 10.10.10.10, rename SQL01, join, move to the Servers OU. Sign in as **adm.sarah.lewis**.
2. With the ISO attached as E:, install silently:

```
$p = Read-Host "svc_sql password"
E:\setup.exe /Q /ACTION=Install /FEATURES=SQLENGINE /INSTANCENAME=MSSQLSERVER
/SQLSVCACCOUNT="LAB\svc_sql" /SQLSVCPASSWORD="$p" /SQLSYSADMINACCOUNTS="LAB\GG-SQL-Admins"
"LAB\Domain Admins" /INSTALLSQLDATADIR="D:\SQL" /TCPENABLED=1 /UPDATEENABLED=0
/IACCEPTSQLSERVERLICENSETERMS
```

3. Open the port and create the database with `MeridianOps.sql` (Appendix D):

```
New-NetFirewallRule -DisplayName "SQL 1433" -Direction Inbound -Protocol TCP -LocalPort 1433 -
Action Allow
sqlcmd -S SQL01 -E -i C:\Lab\MeridianOps.sql
```

Expected result. Tables Customers, Shipments and Invoices with sample rows. GG-Operations can read and write; GG-Finance and GG-Sales can read.

Verify. Run a query from WS01 as aisha.rahman, then on SQL01 check how she signed in:

```
sqlcmd -S SQL01 -E -Q "SELECT s.login_name, c.auth_scheme, c.client_net_address FROM
sys.dm_exec_connections c JOIN sys.dm_exec_sessions s ON s.session_id=c.session_id WHERE
c.client_net_address='10.10.20.21'"
```

Expected: `LAB\aisha.rahman | KERBEROS | 10.10.20.21`.

Common issues. A connection made on SQL01 itself shows NTLM, not Kerberos. That is normal: local connections use shared memory.

Why it matters. Running the service as a domain account with an SPN is common in real companies, and it is what makes weakness 1 (Kerberoasting) work.

Step 4.10 · Build the web server in the DMZ (WEB01)

Purpose. Host Meridian Freight's shipment-tracking website in the DMZ, reading from SQL01 with Kerberos and no stored password.

You need. Steps 4.6 and 4.9 done.

Procedure.

1. On fw01, open the DMZ paths, then Apply:

Interface	Source	Destination	Ports
DMZ	10.10.30.10	10.10.10.10 (DC01)	AD_TCP, AD_UDP
DMZ	10.10.30.10	10.10.10.12 (SQL01)	TCP 1433
USERS	USERS net	10.10.30.10	TCP 80

2. Clone the server template onto **VMnet5**. Set IP 10.10.30.10, gateway 10.10.30.1, DNS 10.10.10.10, rename WEB01, join, and on DC01 create `OU=DMZ` under Computers and move WEB01 into it.
3. Install IIS and create the folders and application pool:

```
Install-WindowsFeature Web-Server,Web-Asp-Net45,Web-Windows-Auth -IncludeManagementTools
New-Item C:\inetpub\meridian, C:\inetpub\staff -ItemType Directory
New-WebAppPool MeridianApp
```

4. In IIS Manager: **Application Pools → MeridianApp → Advanced Settings → Identity → Custom account** → `LAB\svc_web` and its password. Then create the two applications:

```
New-WebApplication -Site "Default Web Site" -Name track -PhysicalPath C:\inetpub\meridian -
ApplicationPool MeridianApp
New-WebApplication -Site "Default Web Site" -Name staff -PhysicalPath C:\inetpub\staff -
ApplicationPool MeridianApp
```

5. On SQL01, give svc_web read access to two tables:

```
sqlcmd -S SQL01 -E -Q "CREATE LOGIN [LAB\svc_web] FROM WINDOWS; USE MeridianOps; CREATE USER
[LAB\svc_web] FOR LOGIN [LAB\svc_web]; GRANT SELECT ON dbo.Shipments TO [LAB\svc_web]; GRANT SELECT
ON dbo.Customers TO [LAB\svc_web];"
```

6. Add the two pages from Appendix D, saving from an **elevated** editor (`notepad C:\inetpub\meridian\Default.aspx` in an admin prompt). /track is public and anonymous; /staff uses Windows sign-in:

```
Set-WebConfigurationProperty -PSPath 'MACHINE/WEBROOT/APPHOST' -Location 'Default Web Site/staff' -
Filter system.webServer/security/authentication/anonymousAuthentication -Name enabled -Value False
Set-WebConfigurationProperty -PSPath 'MACHINE/WEBROOT/APPHOST' -Location 'Default Web Site/staff' -
Filter system.webServer/security/authentication/windowsAuthentication -Name enabled -Value True
```

Expected result. From WS01, `http://web01.lab.local/track/?id=SH-88120` shows *SH-88120 | Northwind Logistics | Felixstowe to Birmingham | Delivered*. `http://web01.lab.local/staff/` shows *Signed in as: LAB<user> (Negotiate)* and the shipment list.

Verify. Load the tracking page, then on SQL01 immediately run:

```
sqlcmd -S SQL01 -E -Q "SELECT s.login_name, c.auth_scheme FROM sys.dm_exec_connections c JOIN
sys.dm_exec_sessions s ON s.session_id=c.session_id WHERE c.client_net_address='10.10.30.10'"
```

Expected: `LAB\svc_web | KERBEROS`. Back up `C:\Windows\System32\inetsrv\config\applicationHost.config` to `C:\Lab` as a clean baseline.

Common issues.

- *Notepad cannot save under C:\inetpub.* It is not elevated (UAC); save to Documents and copy from an elevated prompt, or open Notepad elevated.
- */staff asks for a user name and password.* Edge treats a dotted name like `web01.lab.local` as an Internet-zone site and will not sign in silently. Use `http://web01/staff/`. In my build, /staff was tested by typing credentials at that prompt; the silent sign-in with the short name was **not yet verified**.
- *"Negotiate" does not prove Kerberos.* It means the browser and server negotiated; it can still be NTLM. The 4624 event on WEB01 (Authentication Package field) shows which.
- *Gateway unreachable.* The adapter is not on VMnet5, or not connected.

Why it matters. Joining WEB01 to the domain removes a stored database password but opens a path from the DMZ to DC01, a trade many companies make. The pieces of IIS, for reading its logs and configuration later:

Piece	What it is	Here
Site	A front door bound to an IP and port	Default Web Site, port 80
Application	A URL path mapped to a folder	/track, /staff
Application pool	The worker process (w3wp.exe) and the account it runs as	MeridianApp as LAB\svc_web
Configuration	Sites, pools and authentication settings	`applicationHost.config`

The kernel driver http.sys owns port 80 and routes each request to its pool; w3wp.exe runs the page code. The /staff page identifies the visitor, but its database queries still run as svc_web, because the pool identity does not change per visitor.

Step 4.11 · Build the SIEM (SIEM01)

Purpose. Install Wazuh 4.14 (indexer, server and dashboard on one VM) as the lab's central log platform.

You need. Step 4.5 done (for DNS); about 8 GB of free RAM.

Procedure.

1. New VM on the HDD: 4 vCPU, 8 GB RAM, 100 GB disk, adapter **VMnet2**, Ubuntu Server **24.04 LTS** ISO. Wazuh 4.14 supports Ubuntu up to 24.04; do not use 26.04.
2. Installer choices (keep every other default):

Screen	Choice
Network	ens33 → Edit IPv4 → Manual: subnet 10.10.10.0/24, address 10.10.10.50, gateway 10.10.10.1, name server 10.10.10.10, search domain lab.local
Storage	Use an entire disk; **untick** "Set up this disk as an LVM group"
Profile	Server name `siem01`
SSH	Install OpenSSH server

3. On DC01, add its DNS records (Linux cannot register itself in Windows DNS):

```
Add-DnsServerResourceRecordA -ZoneName lab.local -Name SIEM01 -IPv4Address 10.10.10.50
Add-DnsServerResourceRecordPtr -ZoneName "10.10.10.in-addr.arpa" -Name 50 -PtrDomainName
siem01.lab.local
```

4. From the host, `ssh <user>@10.10.10.50`, then set UTC, take time from DC01, update, and install Wazuh:

```
sudo timedatectl set-timezone UTC
sudo sed -i 's/^#NTP=.*/NTP=10.10.10.10/' /etc/systemd/timesyncd.conf && sudo systemctl restart
systemd-timesyncd
sudo apt update && sudo apt -y upgrade
curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh && sudo bash ./wazuh-install.sh -a
```

Expected result. After 10 to 20 minutes the installer prints the **admin** password. Store it in a password manager, not in a screenshot.

Verify. From the host, `https://10.10.10.50` shows the Wazuh login; after signing in, "no agents registered" is expected.

Common issues.

- *Network screen says "autoconfiguration failed".* Expected on VMnet2, which has no DHCP; set the address manually.
- *Install medium message on reboot.* Click VMware's **I Finished Installing** and press Enter.
- *Lost the admin password.* `sudo tar -O -xvf wazuh-install-files.tar wazuh-install-files/wazuh-passwords.txt`
- *apt cannot connect.* The firewall has no rule letting the Servers zone out to the internet (step 4.3).

Why it matters. One place to search every machine's events. UTC on the server matches the web logs; the dashboard still shows times in your browser's time zone.

Step 4.12 · Add the attacker (KALI01)

Purpose. Place an attacker on the internet side, able to reach only the public website, through the firewall.

You need. Steps 4.3 and 4.10 done.

Procedure.

1. Download the Kali **VMware** prebuilt image (64-bit) from kali.org, extract it with 7-Zip onto the HDD, open the .vmx, rename the VM KALI01. Settings: 2 vCPU, 4 GB RAM, adapter **NAT (VMnet8)**.
2. Sign in as kali/kali and run:

```
passwd
sudo hostnamectl set-hostname kali01
sudo sed -i 's/^127.0.1.1.*/127.0.1.1\tkali01/' /etc/hosts
sudo systemctl enable --now ssh
```

3. On fw01, note the WAN address (**Interfaces → Overview**). Then publish the website:
    1. **Firewall → NAT → Destination NAT** (Port Forward in older versions) → **+**: interface WAN, TCP, destination *WAN address* port 80, redirect to `10.10.30.10` port 80. Save, Apply.
    2. **Firewall → Rules → WAN** → **+**: pass, TCP, source any, destination `10.10.30.10/32`, port 80. Save, Apply. The destination is WEB01's inside address, because the firewall translates the address before checking rules.
4. Close the route around the firewall. On the host, in an elevated PowerShell:

```
Get-Process vmnat | select Path
New-NetFirewallRule -DisplayName "Block VMware NAT into lab" -Direction Outbound -Program
"C:\WINDOWS\SysWOW64\vmnat.exe" -RemoteAddress 10.10.0.0/16 -Action Block
```

Expected result. Kali sees Meridian Freight's website at the firewall's WAN address and nothing else.

Verify. On Kali:

Command	Expected
`curl "http://<fw01 WAN IP>/track/?id=SH-88120"`	The tracking page
`curl -m 5 http://<fw01 WAN IP>:443`	Times out
`ping -c 2 10.10.10.10`	100% loss
`ping -c 2 10.10.20.21`	100% loss

Common issues.

- *Kali can ping DC01 before step 4.* VMware's NAT gateway is a service on the host, and the host has a leg in the Servers network (10.10.10.254), so it relays Kali's traffic straight past fw01. The sign is TTL 128 in the replies; traffic routed through fw01 arrives with 127.
- *Destination NAT creates no rule.* Add the WAN rule by hand (procedure 3.2).
- *Invisible mouse pointer over RDP.* Turn off **Accelerate 3D graphics** in Kali's display settings, or work over SSH from the host.

Why it matters. Attacks arrive the way a real outsider's would: one exposed service, through the firewall, logged on the way in.

Step 4.13 · Add the forensic workstation (ANALYST01)

Purpose. A Windows machine for examining evidence, outside the domain, that can reach Wazuh and the internet and nothing else.

You need. Steps 4.3 and 4.11 done.

Procedure.

1. On fw01, create two aliases (each value entered on its own) and three rules on FORENSICS, in this order:

Alias	Type	Content
PRIVATE_NETS	Network(s)	10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16

Alias	Type	Content
WEB_PORTS	Port(s)	80, 443

#	Protocol	Destination	Port	Purpose
1	TCP/UDP	This Firewall	53	DNS through fw01
2	TCP	10.10.10.50	443	Wazuh dashboard
3	TCP	PRIVATE_NETS with **Invert** ticked	WEB_PORTS	Internet only

2. Full clone of Win11-Base onto the HDD: 4 vCPU, 8 GB RAM, adapter **VMnet6** set before first boot, plus a 150 GB evidence disk. Under **Options → VMware Tools**, tick **Synchronize guest time with host**.
3. Create a local account; do not join the domain. Then:

```
New-NetIPAddress -InterfaceAlias "Ethernet0" -IPAddress 10.10.40.10 -PrefixLength 24 -
DefaultGateway 10.10.40.1
Set-DnsClientServerAddress -InterfaceAlias "Ethernet0" -ServerAddresses 10.10.40.1
w32tm /config /syncfromflags:NO /update
Rename-Computer -NewName ANALYST01 -Restart
```

4. After the restart, prepare the evidence drive and tool folder:

```
Get-Disk | ? PartitionStyle -eq RAW | Initialize-Disk -PartitionStyle GPT -PassThru | New-Partition
-DriveLetter E -UseMaximumSize | Format-Volume -FileSystem NTFS -NewFileSystemLabel EVIDENCE
New-Item E:\Cases, C:\Tools -ItemType Directory
Add-MpPreference -ExclusionPath C:\Tools, E:\Cases
```

5. Install the toolset: Eric Zimmerman's tools (`Get-ZimmermanTools.ps1 -Dest C:\Tools\EZ`), KAPE, Sysinternals Suite, FTK Imager, Arsenal Image Mounter, Python with Volatility 3 (`pip install volatility3`), Notepad++ and 7-Zip.

Expected result. ANALYST01 is isolated but can open Wazuh and download tools.

Verify.

Command	Expected
`Test-NetConnection 10.10.10.50 -Port 443`	True
`Resolve-DnsName microsoft.com`	Resolves
`Test-NetConnection 10.10.10.10 -Port 445`	False

Common issues.

- *Everything times out and fw01 logs the traffic on WAN.* The clone kept NAT; move its adapter to VMnet6.
- *FORENSICS shows red with no address on fw01.* The interface was assigned but not enabled.
- *Windows time will not sync from fw01.* Not needed here; VMware Tools takes the time from the host.

Why it matters. Evidence work belongs on a machine the compromised domain cannot reach. The Defender exclusion is acceptable only because the machine is isolated.

05 Validation and troubleshooting

Run this checklist once the build is finished, and again after any big change. Every line should pass before you use the lab for an exercise.

End-to-end checklist

#	Check	How	Expected	Built in
1	Firewall interfaces up	fw01 **Interfaces → Overview**	Five green interfaces with addresses	4.3
2	Domain and DNS	`Resolve-DnsName dc01.lab.local` on any domain PC	10.10.10.10	4.5
3	Company directory	`(Get-ADUser -Filter * -SearchBase "OU=Corp,DC=lab,DC=local").Count`	29	4.6
4	Share permissions	`Get-ChildItem \\FS01\HR` as a Finance user	Access denied	4.8
5	Drive mapping	Sign in to WS01 as aisha.rahman	P: and S: present	4.8
6	SQL over Kerberos	`auth_scheme` query on SQL01	KERBEROS	4.9
7	Website and DMZ path	Tracking page from WS01; `auth_scheme` for 10.10.30.10	Page loads; svc_web over KERBEROS	4.10
8	SIEM reachable	`https://10.10.10.50` from the host	Wazuh login	4.11
9	Outside view	Kali: curl to the WAN address, ping to 10.10.10.10	Page loads; ping fails	4.12
10	Forensics isolation	ANALYST01: port 443 to SIEM01, port 445 to DC01	True; False	4.13
11	Audit policy	`auditpol /get /subcategory:"Process Creation"`	Success	06

Starting and stopping the lab

Start in dependency order, about a minute apart: **fw01 → DC01 → FS01, SQL01 → WEB01, SIEM01 → workstations → KALI01 or ANALYST01** only when needed.

Shut down in the reverse order, DC01 and fw01 last. Use **VM → Power → Shut Down Guest**, which shuts Windows down properly. Avoid **Power Off** on a running machine: it is the same as pulling the plug.

If a VM hangs at "Attempting to start up from Windows Boot Manager" or a black screen, the host is usually out of RAM or disk throughput. Check the host's Task Manager, shut down VMs you do not need, and wait a few minutes before resetting.

Problems met during the build

Every row happened in the real build. Each also appears beside its step in chapter 04.

Symptom	Cause	Fix	Confirm
Server missing from DNS after joining	Joined under its random setup name	Rename, then rejoin; clean up the old record	`Resolve-DnsName <name>`
"The domain isn't available" at sign-in	Network adapter not connected	Tick Connected and Connect at power on	Sign-in succeeds
A clone's traffic is blocked on fw01's WAN	Clone kept the template's NAT adapter	Set the zone's VMnet	`arp -a` shows the gateway
Test-Path says a user can reach a share they cannot	Test-Path only checks existence	Use Get-ChildItem	Access denied
Firewall rule never matches	Source port fixed, rule not applied, or a block rule above	Source port any, Apply, reorder	Traffic passes
LAN and WAN both fail after adding a NIC	New card took a lower PCI slot; names shifted	Reassign VMware adapters to match slot order	All interfaces green
Kali can ping DC01	Host's NAT service relays into the Servers network	Block vmnat.exe to 10.10.0.0/16 on the host	Ping fails, website still loads
FORENSICS has no address	Interface assigned, never enabled	Enable, static 10.10.40.1/24, Apply	Green in Overview
Alias rejected as "not a network"	Leading space in the value	Retype without spaces	Alias saves
Notepad cannot save in C:\inetpub	Notepad not elevated	Open it from an admin prompt	File saves
/staff prompts for a password	Dotted name puts the site in the Internet zone	Use the short name	No prompt
Ubuntu root fills early	LVM default gives root about half the disk	Untick LVM at install	`df -h /` shows the full disk
PTR record fails to create	Missing reverse zone or IP typo	Create the zone; check the address	`Resolve-DnsName <IP>`
Audit GPO applied, auditpol shows No Auditing	GPO missing the audit extension GUID	Re-save one audit subcategory (06)	auditpol shows Success
Windows VM boots into Automatic Repair	Host lost power or restarted with VMs running	Let repair run; fix power settings	Windows starts
Windows will not sync time from fw01	fw01 NTP not yet trusting its upstream servers	Wait about 10 minutes, or use VMware Tools time sync	`w32tm /query /status`
Invisible pointer in Kali over RDP	3D acceleration with nested remote display	Turn off 3D acceleration, or use SSH	Pointer visible

Not yet verified

These were not tested end to end in my build. Treat them as expected behaviour, not confirmed results:

- Silent Windows sign-in to /staff using the short name, and the HTTP Kerberos ticket that goes with it.

- The firewall rule tables in steps 4.3, 4.8 and 4.10 describe the design; compare them with your own fw01 rule list.

06 Making the lab DFIR-ready

A working network is not yet a useful investigation range. Out of the box, Windows keeps little of the evidence you need. This chapter turns on the right logs, sets up snapshots and evidence habits, and then proves that a known action really leaves a trace.

6.1 Audit policy for every domain machine

Purpose. Record logons, Kerberos activity, account changes, share access and every program started, with its command line.

Procedure.

1. On DC01, create the GPO and link it to the domain and to Domain Controllers:

```
New-GPO -Name "LAB-Audit-Policy" | New-GPLink -Target "DC=lab,DC=local"
New-GPLink -Name "LAB-Audit-Policy" -Target "OU=Domain Controllers,DC=lab,DC=local" -Order 1
```

2. Edit it in `gpmc.msc` (right-click → Edit). Everything is under **Computer Configuration → Policies**:
   - **Windows Settings → Security Settings → Advanced Audit Policy Configuration → Audit Policies**: set the subcategories in the table below.
   - **Security Settings → Local Policies → Security Options**: *Audit: Force audit policy subcategory settings to override audit policy category settings* = **Enabled**. Leave **Local Policies → Audit Policy** entirely Not Defined.
   - **Security Settings → Event Log**: maximum security log size **1048576** KB, retention *Overwrite events as needed*.
   - **Administrative Templates → System → Audit Process Creation**: *Include command line in process creation events* = **Enabled**.
   - **Administrative Templates → Windows Components → Windows PowerShell**: *Turn on Module Logging* = Enabled with module `*`; *Turn on PowerShell Script Block Logging* = Enabled.

Category	Subcategory	Audit
Account Logon	Credential Validation; Kerberos Authentication Service; Kerberos Service Ticket Operations	Success, Failure
Account Management	Computer, Security Group and User Account Management	Success, Failure
Detailed Tracking	Process Creation	Success
DS Access	Directory Service Access	Success, Failure
DS Access	Directory Service Changes	Success
Logon/Logoff	Logon	Success, Failure
Logon/Logoff	Logoff; Special Logon	Success
Logon/Logoff	Account Lockout	Failure

Category	Subcategory	Audit
Object Access	File Share; Removable Storage	Success, Failure
Object Access	Detailed File Share	Failure
Policy Change	Audit Policy Change; Authentication Policy Change	Success
Privilege Use	Sensitive Privilege Use	Success, Failure
System	Security State Change; Security System Extension	Success

3. Check that the GPO really carries the audit settings. On DC01:

```
$id = (Get-GPO -Name "LAB-Audit-Policy").Id
Get-ADObject "CN={$id},CN=Policies,CN=System,DC=lab,DC=local" -Properties gPCMachineExtensionNames
| select -Expand gPCMachineExtensionNames
```

The output must contain `{F3CCC681-B74C-4060-9F26-CD84525DCA2A}`. In my build it did not: the GPO looked perfect and changed nothing. If it is missing, open any one audit subcategory in the editor, untick Success, click OK, tick it again, click OK. That re-save registers it.

Verify. On FS01, `gpupdate /force`, then `auditpol /get /category:* | findstr /i "Process Kerberos Share"`. Expected: File Share *Success and Failure*, Detailed File Share *Failure*, Process Creation *Success*, both Kerberos lines *Success and Failure*.

Why it matters. Without command-line logging, event 4688 says a program ran but not what it was told to do. The default 20 MB Security log lasts only hours on a domain controller.

6.2 Web server logs

On WEB01, log every IIS field:

```
Set-WebConfigurationProperty -PSPath 'MACHINE/WEBROOT/APPHOST' -Filter
"system.applicationHost/sites/siteDefaults/logFile" -Name logExtFileFlags -Value
"Date,Time,ClientIP,UserName,SiteName,ComputerName,ServerIP,Method,UriStem,UriQuery,HttpStatus,Win3
2Status,BytesSent,BytesRecv,TimeTaken,ServerPort,UserAgent,Cookie,Referer,ProtocolVersion,Host,Http
SubStatus"
```

Logs are in `C:\inetpub\logs\LogFiles\W3SVC1\u_exYYMMDD.log`. Three things to know when reading them:

- Times are UTC, and lines are written in batches, so a request can take a minute to appear.
- On /track, `cs-username` is always `-`: visitors are anonymous. The only account in that chain is svc_web, visible on SQL01.
- On /staff, each visit logs a 401 (the sign-in challenge) followed by a 200 with the user's name. That pair is normal, not a failed logon.

6.3 Snapshots

Take a snapshot of each VM when its step's Verify passes (names in Appendix C), and one more of every Windows VM after 6.1, called `logging-baseline`. Reverting to these resets a scenario in minutes. Keep a dated fw01 configuration backup after every rule change; it is a small XML file and restores the whole firewall.

6.4 Evidence handling habits

Practise these from the first exercise, so they are automatic on real work:

- **One folder per case** on ANALYST01: `E:\Cases\<case>\evidence` for originals, `\working` for copies you process, `\notes` for your log.
- **Hash on arrival.** `Get-FileHash <file> -Algorithm SHA256` before you open anything; record the value in your notes.
- **Work on copies.** Never run tools against the original.
- **Write times in UTC**, with the source of each time (log, file system, your own action).
- **Capturing a VM.** Suspending a VM writes its memory to `.vmem` and `.vmss` files beside the VM, which memory tools can read. A powered-off VM's `.vmdk` disk can be copied as a disk image. Note the snapshot name and time of every capture.

6.5 Prove that evidence is captured

Run a known action and find its trace. If you cannot find it, the lab is not ready for that kind of exercise yet.

Action	Where to look	Expected evidence
On WS01 as aisha.rahman, run `whoami /all`	WS01 Security log	Event 4688 with the full command line
Open `\\FS01\Finance` from WS01	DC01 Security log; FS01 Security log	4769 ticket request for FS01; 5140 share access
Load the tracking page from WS01	WEB01 IIS log	A GET for `/track/` from 10.10.20.21
Run any PowerShell command on FS01	Microsoft-Windows-PowerShell/Operational	Event 4104 with the script text

In my build, row 3 was confirmed in the IIS log. The other rows follow from the audit settings above but were not yet checked event by event.

07 Appendices and next steps

Appendix A · Machine inventory

Host	Role	Zone (VMnet)	IP	OS	vCPU / RAM	In domain
fw01	Firewall, router, DNS resolver	All five	WAN DHCP; .1 in each zone	OPNsense 26.7	2 / 2 GB	No
DC01	Domain controller, DNS	Servers (VMnet2)	10.10.10.10	Windows Server 2022	2 / 4 GB	Yes
FS01	File server	Servers (VMnet2)	10.10.10.11	Windows Server 2022	2 / 4 GB	Yes
SQL01	SQL Server 2022	Servers (VMnet2)	10.10.10.12	Windows Server 2022	2 / 8 GB	Yes
SIEM01	Wazuh 4.14	Servers (VMnet2)	10.10.10.50	Ubuntu 24.04	4 / 8 GB	No
WS01	Finance PC	Users (VMnet4)	10.10.20.21	Windows 11	2 / 4 GB	Yes
WS02	Staff PC	Users (VMnet4)	10.10.20.22	Windows 11	2 / 4 GB	Yes
WS03	HR PC	Users (VMnet4)	10.10.20.23	Windows 11	2 / 4 GB	Yes
WEB01	IIS website	DMZ (VMnet5)	10.10.30.10	Windows Server 2022	2 / 4 GB	Yes
ANALYST01	Forensic workstation	Forensics (VMnet6)	10.10.40.10	Windows 11	4 / 8 GB	No
KALI01	Attacker	Internet (VMnet8)	DHCP	Kali 2026.3	2 / 4 GB	No
Host	Management only	Servers (VMnet2)	10.10.10.254	Windows 11 Pro	—	No

Appendix B · Accounts and rights

Account or group	Type	Rights	Note
24 staff (e.g. aisha.rahman)	User	Own department share; SQL through GG-<dept>	Day-to-day accounts
adm.ravi.kumar, adm.sarah.lewis	Admin	Domain Admins	Admin tasks only
GG-SQL-Admins (sarah.lewis)	Group	sysadmin on SQL01	
GG-Helpdesk (tom.becker)	Group	Reset any staff password	Weakness 4

Account or group	Type	Rights	Note
svc_sql	Service	Runs SQL Server; SPN MSSQLSvc/SQL01.lab.local:1433	Weakness 1
svc_backup	Service	Backup Operators	Weakness 3
svc_web	Service	Runs the MeridianApp pool; SELECT on Shipments and Customers	
chloe.martin	User	Sales	Weakness 2

Appendix C · Snapshot guide

VM	Snapshot	Take it after
fw01	fw01-base, plus a config backup after each rule change	4.3, 4.8, 4.10, 4.12, 4.13
DC01	dc01-org	4.6
FS01	fs01-shares-populated	4.7
WS01 to WS03	ws0N-joined	4.8
SQL01	sql01-db-ready	4.9
WEB01	web01-iis	4.10
SIEM01	siem01-installed	4.11
KALI01	kali01-clean	4.12
ANALYST01	analyst01-clean	4.13
All Windows VMs	logging-baseline	6.1

Appendix D · Scripts

Lab use only. `New-LabOrg.ps1` is reproduced exactly as used in my build. The others were rewritten for this guide from the build notes; compare them with your own copies before relying on them.

Script	Run on	When	What it changes	Check
New-LabOrg.ps1	DC01	4.6	Creates OUs, groups, 29 accounts, four weaknesses	29 accounts under OU=Corp
New-LabShares.ps1	FS01	4.7	Creates seven folders, NTFS permissions, shares	`Get-SmbShare` lists seven
Seed data	FS01	4.7	Writes sample files into the shares	Files visible in each share
MapDrives.cmd / .ps1	NETLOGON	4.8	Maps P: and S: at sign-in	Drives appear for a staff user
MeridianOps.sql	SQL01	4.9	Creates the database, tables, rows and access	Query returns rows
Default.aspx (/track, /staff)	WEB01	4.10	The two web pages	Pages load

MapDrives.cmd

```
@echo off
powershell.exe -NoProfile -ExecutionPolicy Bypass -WindowStyle Hidden -File "%~dp0MapDrives.ps1"
```

MapDrives.ps1

```
$groups = ([Security.Principal.WindowsIdentity]::GetCurrent()).Groups |
    ForEach-Object { $_.Translate([Security.Principal.NTAccount]).Value }
net use P: \\FS01\Public /persistent:no | Out-Null
foreach ($d in 'IT','HR','Finance','Sales','Operations','Management') {
    if ($groups -contains "LAB\GG-$d") { net use S: "\\FS01\$d" /persistent:no | Out-Null; break }
}
```

New-LabShares.ps1

```
$shares = @{ IT='GG-IT'; HR='GG-HR'; Finance='GG-Finance'; Sales='GG-Sales'
             Operations='GG-Operations'; Management='GG-Management'; Public='Domain Users' }
foreach ($name in $shares.Keys) {
    $path = "D:\Shares\$name"
    New-Item $path -ItemType Directory -Force | Out-Null
    $acl = Get-Acl $path
    $acl.SetAccessRuleProtection($true, $false)
    $acl.Access | ForEach-Object { $acl.RemoveAccessRule($_) | Out-Null }
    foreach ($id in 'BUILTIN\Administrators','NT AUTHORITY\SYSTEM') {
        $acl.AddAccessRule((New-Object
Security.AccessControl.FileSystemAccessRule($id,'FullControl','ContainerInherit,ObjectInherit','Non
e','Allow')))
    }
    $acl.AddAccessRule((New-Object
Security.AccessControl.FileSystemAccessRule("LAB\$($shares[$name])",'Modify','ContainerInherit,Obje
ctInherit','None','Allow')))
    Set-Acl $path $acl
    if (-not (Get-SmbShare -Name $name -ErrorAction SilentlyContinue)) {
        New-SmbShare -Name $name -Path $path -FullAccess 'BUILTIN\Administrators' -ChangeAccess 'NT
AUTHORITY\Authenticated Users' -FolderEnumerationMode AccessBased | Out-Null
    }
}
```

Seed data

```
function New-LabFile($Share, $Name, $Text) { Set-Content -Path "D:\Shares\$Share\$Name" -Value
$Text }
New-LabFile Finance 'Payroll_2026-09.csv' "Employee,Department,Net`nAisha
Rahman,Finance,3120.00`nTom Becker,IT,2890.00"
New-LabFile Finance 'Invoices_Q3.csv' "Invoice,Customer,Amount`nINV-4101,Northwind
Logistics,18450.00"
```

```
New-LabFile HR 'Offer_Letter_Template.txt' "Dear candidate, we are pleased to offer you the role of
..."
New-LabFile Sales 'Customer_List.csv' "Customer,Contact,City`nNorthwind Logistics,Accounts
Team,Birmingham"
New-LabFile Operations 'Delivery_Schedule.csv' "Shipment,Route,Date`nSH-88121,Birmingham-
Leeds,2026-10-27"
New-LabFile Management 'Board_Notes_Oct.txt' "Q4 priorities: new depot, fleet renewal, pricing
review."
New-LabFile Public 'Holiday_Calendar_2026.txt' "Office closed 25-26 December."
```

MeridianOps.sql

```
CREATE DATABASE MeridianOps;
GO
USE MeridianOps;
GO
CREATE TABLE dbo.Customers (CustomerId INT PRIMARY KEY, Name NVARCHAR(100), City NVARCHAR(50));
CREATE TABLE dbo.Shipments (ShipmentId NVARCHAR(10) PRIMARY KEY, CustomerId INT REFERENCES
dbo.Customers,
    Origin NVARCHAR(50), Destination NVARCHAR(50), Status NVARCHAR(20));
CREATE TABLE dbo.Invoices (InvoiceId NVARCHAR(10) PRIMARY KEY, CustomerId INT REFERENCES
dbo.Customers,
    Amount DECIMAL(10,2), Paid BIT);
INSERT dbo.Customers VALUES (1,'Northwind Logistics','Birmingham'),(2,'Harbour and Hale
Retail','Leeds'),(3,'Pennine Foods','Manchester');
INSERT dbo.Shipments VALUES ('SH-88120',1,'Felixstowe','Birmingham','Delivered'),
    ('SH-88121',2,'Birmingham','Leeds','In transit'),('SH-
88122',3,'Southampton','Manchester','Booked');
INSERT dbo.Invoices VALUES ('INV-4101',1,18450.00,1),('INV-4102',2,7320.50,0),('INV-
4103',3,12980.00,0);
GO
CREATE LOGIN [LAB\GG-Operations] FROM WINDOWS;  CREATE USER [LAB\GG-Operations] FOR LOGIN [LAB\GG-
Operations];
CREATE LOGIN [LAB\GG-Finance] FROM WINDOWS;     CREATE USER [LAB\GG-Finance] FOR LOGIN [LAB\GG-
Finance];
CREATE LOGIN [LAB\GG-Sales] FROM WINDOWS;       CREATE USER [LAB\GG-Sales] FOR LOGIN [LAB\GG-
Sales];
ALTER ROLE db_datareader ADD MEMBER [LAB\GG-Operations];
ALTER ROLE db_datawriter ADD MEMBER [LAB\GG-Operations];
GRANT SELECT ON dbo.Invoices TO [LAB\GG-Finance];  GRANT SELECT ON dbo.Customers TO [LAB\GG-
Finance];
GRANT SELECT ON dbo.Customers TO [LAB\GG-Sales];   GRANT SELECT ON dbo.Shipments TO [LAB\GG-Sales];
GO
```

Default.aspx for /track (`C:\inetpub\meridian`)

```
<%@ Page Language="C#" %>
<%@ Import Namespace="System.Data.SqlClient" %>
<html><body>
<h2>Meridian Freight - Track a shipment</h2>
<form method="get">Shipment ID: <input name="id" /> <input type="submit" value="Track" /></form>
<%
string id = Request.QueryString["id"];
if (!String.IsNullOrEmpty(id)) {
  using (var c = new SqlConnection("Server=SQL01.lab.local;Database=MeridianOps;Integrated
Security=True")) {
    c.Open();
    var q = new SqlCommand("SELECT s.ShipmentId, cu.Name, s.Origin, s.Destination, s.Status FROM
dbo.Shipments s JOIN dbo.Customers cu ON cu.CustomerId = s.CustomerId WHERE s.ShipmentId = @id",
c);
    q.Parameters.AddWithValue("@id", id);
    using (var r = q.ExecuteReader()) {
      if (r.Read()) { Response.Write("<p>" + Server.HtmlEncode(r[0] + " | " + r[1] + " | " + r[2] +
" to " + r[3] + " | " + r[4]) + "</p>"); }
      else { Response.Write("<p>Shipment not found.</p>"); }
    }
  }
}
%>
</body></html>
```

Default.aspx for /staff (`C:\inetpub\staff`)

```
<%@ Page Language="C#" %>
<%@ Import Namespace="System.Data.SqlClient" %>
<html><body>
<h2>Meridian Freight - Staff portal</h2>
<p>Signed in as: <%= Server.HtmlEncode(User.Identity.Name) %> (<%= User.Identity.AuthenticationType
%>)</p>
<h3>Shipments</h3>
<%
using (var c = new SqlConnection("Server=SQL01.lab.local;Database=MeridianOps;Integrated
Security=True")) {
  c.Open();
  var q = new SqlCommand("SELECT ShipmentId, Origin, Destination, Status FROM dbo.Shipments", c);
  using (var r = q.ExecuteReader()) {
    while (r.Read()) { Response.Write("<p>" + Server.HtmlEncode(r[0] + " | " + r[1] + " to " + r[2]
+ " | " + r[3]) + "</p>"); }
  }
}
%>
</body></html>
```

New-LabOrg.ps1 (exactly as used)

```
<#
.SYNOPSIS
  Builds the fictional company "Meridian Freight" in the lab.local domain.

.DESCRIPTION
  Run on DC01 as LAB\Administrator in an elevated PowerShell window:
      Set-ExecutionPolicy -Scope Process Bypass -Force
      .\New-LabOrg.ps1

  Creates:
    - OU tree under OU=Corp (Users by department, Computers, Groups, Service Accounts, Admins)
    - 24 staff accounts across 6 departments + department security groups
    - 2 tiered admin accounts (Domain Admins) and a Helpdesk group with password-reset rights
    - 3 service accounts
    - Redirects newly joined computers into OU=Workstations

  DELIBERATE WEAKNESSES (lab training targets - never do this in production):
    1. svc_sql has an SPN and a non-expiring password      -> Kerberoasting
    2. chloe.martin does not require Kerberos pre-auth     -> AS-REP roasting
    3. svc_backup is in Backup Operators, never expires    -> privilege abuse
    4. GG-Helpdesk can reset passwords on all staff        -> ACL abuse path

  Safe to re-run: existing objects are skipped.
  LAB USE ONLY.
#>

#Requires -Modules ActiveDirectory
$ErrorActionPreference = 'Stop'
Import-Module ActiveDirectory

$domain   = Get-ADDomain
$domainDN = $domain.DistinguishedName
$upnSfx   = $domain.DNSRoot
$netbios  = $domain.NetBIOSName
$company  = 'Meridian Freight'

$pw = Read-Host -AsSecureString 'Password for ALL lab accounts (must meet complexity rules)'

# ---------- helpers ----------
function Ensure-OU {
    param([string]$Name, [string]$Path)
    $dn = "OU=$Name,$Path"
    try   { Get-ADOrganizationalUnit -Identity $dn | Out-Null }
    catch {
        New-ADOrganizationalUnit -Name $Name -Path $Path -ProtectedFromAccidentalDeletion $true
        Write-Host "[+] OU      $dn" -ForegroundColor Green
```

```
    }
    return $dn
}

function Ensure-Group {
    param([string]$Name, [string]$Path, [string]$Desc)
    if (-not (Get-ADGroup -Filter "Name -eq '$Name'")) {
        New-ADGroup -Name $Name -GroupScope Global -GroupCategory Security -Path $Path -Description
$Desc
        Write-Host "[+] Group   $Name" -ForegroundColor Green
    }
}

function Ensure-User {
    param([string]$Sam, [string]$Given, [string]$Sur, [string]$Path,
          [string]$Title, [string]$Dept, [string]$Display)
    if (Get-ADUser -Filter "SamAccountName -eq '$Sam'") {
        Write-Host "[=] Exists  $Sam" -ForegroundColor Yellow
        return
    }
    if (-not $Display) { $Display = "$Given $Sur" }
    New-ADUser -Name $Display -GivenName $Given -Surname $Sur -DisplayName $Display `
        -SamAccountName $Sam -UserPrincipalName "$Sam@$upnSfx" `
        -Title $Title -Department $Dept -Company $company `
        -Path $Path -AccountPassword $pw -Enabled $true -ChangePasswordAtLogon $false
    Write-Host "[+] User    $Sam  ($Title, $Dept)" -ForegroundColor Green
}

# ---------- OU tree ----------
$corp      = Ensure-OU 'Corp'             $domainDN
$usersOU   = Ensure-OU 'Users'            $corp
$compOU    = Ensure-OU 'Computers'        $corp
$groupsOU  = Ensure-OU 'Groups'           $corp
$svcOU     = Ensure-OU 'Service Accounts' $corp
$adminsOU  = Ensure-OU 'Admins'           $corp
$wksOU     = Ensure-OU 'Workstations'     $compOU
$srvOU     = Ensure-OU 'Servers'          $compOU

$depts = 'IT','HR','Finance','Sales','Operations','Management'
$deptOU = @{}
foreach ($d in $depts) {
    $deptOU[$d] = Ensure-OU $d $usersOU
    Ensure-Group "GG-$d" $groupsOU "All $d staff"
}
Ensure-Group 'GG-Helpdesk'   $groupsOU 'Helpdesk - can reset staff passwords'
Ensure-Group 'GG-SQL-Admins' $groupsOU 'SQL Server administrators'

# ---------- staff (fictional) ----------
```

```
$staff = @(
  # Sam                Given        Surname      Dept          Title
  @('ravi.kumar',      'Ravi',      'Kumar',     'IT',         'IT Manager'),
  @('sarah.lewis',     'Sarah',     'Lewis',     'IT',         'Systems Administrator'),
  @('tom.becker',      'Tom',       'Becker',    'IT',         'Helpdesk Technician'),
  @('priya.nair',      'Priya',     'Nair',      'HR',         'HR Manager'),
  @('daniel.okafor',   'Daniel',    'Okafor',    'HR',         'HR Officer'),
  @('emma.clarke',     'Emma',      'Clarke',    'HR',         'Recruiter'),
  @('michael.chen',    'Michael',   'Chen',      'Finance',    'Finance Director'),
  @('aisha.rahman',    'Aisha',     'Rahman',    'Finance',    'Accountant'),
  @('lucas.moreau',    'Lucas',     'Moreau',    'Finance',    'Accounts Payable Clerk'),
  @('neha.gupta',      'Neha',      'Gupta',     'Finance',    'Payroll Specialist'),
  @('james.walker',    'James',     'Walker',    'Sales',      'Sales Manager'),
  @('olivia.brown',    'Olivia',    'Brown',     'Sales',      'Account Executive'),
  @('arjun.mehta',     'Arjun',     'Mehta',     'Sales',      'Account Executive'),
  @('chloe.martin',    'Chloe',     'Martin',    'Sales',      'Sales Coordinator'),
  @('ben.taylor',      'Ben',       'Taylor',    'Sales',      'Business Development Rep'),
  @('david.wilson',    'David',     'Wilson',    'Operations', 'Operations Manager'),
  @('fatima.ali',      'Fatima',    'Ali',       'Operations', 'Logistics Coordinator'),
  @('kenji.tanaka',    'Kenji',     'Tanaka',    'Operations', 'Warehouse Supervisor'),
  @('grace.kim',       'Grace',     'Kim',       'Operations', 'Dispatcher'),
  @('mohammed.hassan', 'Mohammed',  'Hassan',    'Operations', 'Fleet Coordinator'),
  @('lily.evans',      'Lily',      'Evans',     'Operations', 'Inventory Analyst'),
  @('elizabeth.shaw',  'Elizabeth', 'Shaw',      'Management', 'Chief Executive Officer'),
  @('robert.singh',    'Robert',    'Singh',     'Management', 'Chief Operating Officer'),
  @('anna.kowalski',   'Anna',      'Kowalski',  'Management', 'Executive Assistant')
)

foreach ($s in $staff) {
    $sam, $given, $sur, $dept, $title = $s
    Ensure-User -Sam $sam -Given $given -Sur $sur -Path $deptOU[$dept] -Title $title -Dept $dept
    Add-ADGroupMember -Identity "GG-$dept" -Members $sam -ErrorAction SilentlyContinue
}
Add-ADGroupMember -Identity 'GG-Helpdesk'   -Members 'tom.becker'  -ErrorAction SilentlyContinue
Add-ADGroupMember -Identity 'GG-SQL-Admins' -Members 'sarah.lewis' -ErrorAction SilentlyContinue

# ---------- tiered admin accounts ----------
Ensure-User -Sam 'adm.ravi.kumar'  -Given 'Ravi'  -Sur 'Kumar' -Path $adminsOU -Title 'IT Manager
(admin)'           -Dept 'IT' -Display 'Ravi Kumar (admin)'
Ensure-User -Sam 'adm.sarah.lewis' -Given 'Sarah' -Sur 'Lewis' -Path $adminsOU -Title 'Systems
Administrator (admin)' -Dept 'IT' -Display 'Sarah Lewis (admin)'
Add-ADGroupMember -Identity 'Domain Admins' -Members 'adm.ravi.kumar','adm.sarah.lewis' -
ErrorAction SilentlyContinue

# ---------- service accounts ----------
Ensure-User -Sam 'svc_sql'    -Given 'SQL'    -Sur 'Service' -Path $svcOU -Title 'SQL Server
service account' -Dept 'IT' -Display 'svc_sql'
Ensure-User -Sam 'svc_backup' -Given 'Backup' -Sur 'Service' -Path $svcOU -Title 'Backup service
```

```
account'     -Dept 'IT' -Display 'svc_backup'
Ensure-User -Sam 'svc_web'    -Given 'Web'    -Sur 'Service' -Path $svcOU -Title 'Web app pool
account'       -Dept 'IT' -Display 'svc_web'

# ---------- deliberate weaknesses ----------
# 1. Kerberoastable service account
Set-ADUser -Identity 'svc_sql' -ServicePrincipalNames
@{Add="MSSQLSvc/SQL01.${upnSfx}:1433","MSSQLSvc/SQL01.${upnSfx}"} -PasswordNeverExpires $true
# 2. AS-REP roastable user
Set-ADAccountControl -Identity 'chloe.martin' -DoesNotRequirePreAuth $true
# 3. Over-privileged backup account
Set-ADUser -Identity 'svc_backup' -PasswordNeverExpires $true
Add-ADGroupMember -Identity 'Backup Operators' -Members 'svc_backup' -ErrorAction SilentlyContinue
# 4. Helpdesk can reset every staff password (ACL abuse path)
dsacls $usersOU /I:S /G "$netbios\GG-Helpdesk:CA;Reset Password;user" | Out-Null

# ---------- new computers land in Workstations OU ----------
redircmp $wksOU | Out-Null

# ---------- summary ----------
Write-Host ""
Write-Host "Meridian Freight build complete in $upnSfx" -ForegroundColor Cyan
Write-Host ("  Staff accounts : {0}" -f (Get-ADUser -Filter * -SearchBase $usersOU).Count)
Write-Host ("  Admin accounts : {0}" -f (Get-ADUser -Filter * -SearchBase $adminsOU).Count)
Write-Host ("  Service accts  : {0}" -f (Get-ADUser -Filter * -SearchBase $svcOU).Count)
Write-Host "  New computers  -> $wksOU"
Write-Host "  Deliberate weaknesses: svc_sql (Kerberoast), chloe.martin (AS-REP), svc_backup
(Backup Operators), GG-Helpdesk (reset-password ACL)" -ForegroundColor Yellow
```

Appendix E · Glossary

Term	Meaning in this guide
AD (Active Directory)	Microsoft's directory of users, computers and groups; runs on DC01
Alias (OPNsense)	A named list of addresses or ports reused across firewall rules
Access-based enumeration	Hides folders a user cannot open inside a share
App pool	The IIS worker process and the account it runs as
DMZ	A network zone for servers the internet can reach
Destination NAT / port forward	Sends traffic for the firewall's public address to an inside server
GPO	Group Policy Object: settings pushed from DC01 to domain machines
Kerberos	The domain's sign-in protocol, based on tickets from DC01
NETLOGON	The shared scripts folder every domain computer can read
NTFS permissions	File and folder permissions on the disk itself

Term	Meaning in this guide
PTR record	Reverse DNS: turns an IP address into a name
SIEM	A system that collects and searches logs from many machines; Wazuh here
SPN	Service Principal Name: ties a service to the account it runs as
Sysprep	Strips a Windows install's identity so it can be cloned
VMnet	A VMware virtual network

Next steps

The lab is built. These come after it, and are not needed to use it:

1. **Wazuh agents** on the Windows machines, sending their Security and PowerShell logs to SIEM01. The firewall must allow TCP 1514 and 1515 to SIEM01 from each zone.
2. **Firewall logs to Wazuh** over syslog, so connections sit beside Windows events.
3. **Sysmon** on the Windows machines for richer process, network and file telemetry.

Investigations to try

Each starts from something built into the lab. Run the attack from KALI01 or a workstation, investigate from ANALYST01, then revert to snapshots.

Scenario	Starting point	Where the evidence lands
Kerberoasting	svc_sql's SPN	DC01: 4769 events requesting the SQL service ticket
AS-REP roasting	chloe.martin without pre-authentication	DC01: 4768 events without pre-authentication
Helpdesk password reset abuse	GG-Helpdesk's reset right	DC01: 4724 password resets, 4738 account changes
HR user browsing Finance	Share permissions on FS01	FS01: 5140 and 5145 share access and failures
Web probing from outside	Port forward to WEB01	WEB01 IIS log; fw01 firewall log
Admin account used on a workstation	Tiered admin accounts	Workstation: 4624 logon by an adm.* account